

Engenharia de Software Seguro

PROF: THYAGO AQUINO



Visão Geral da Trilha de Aprendizado

INTEGRAR SEGURANÇA NO SDLC

O objetivo principal é **integrar segurança** em todas as etapas do ciclo de vida de desenvolvimento de software (SDLC), promovendo uma abordagem abrangente.

PILARES DE SEGURANÇA

Segurança integrada em todas as fases do Ciclo de Vida de Desenvolvimento de Software (SDLC)

Requisitos

Definir requisitos de segurança, identificar riscos e definir controles de segurança.



Design

Criar arquitetura segura e fazer análises de ameaças.

Análise

Realizar uma análise detalhada e revisão dos requisitos e controles de segurança.



Desenvolvimento

Escrever código seguro, realizar revisões e utilizar ferramentas de segurança.

Codificação

Escrever código seguro, realizar revisões e utilizar ferramentas de segurança.



Testes

Realizar testes de segurança, como análise estática e testes de penetração.

Implantação

Usar configurações seguras, escanear vulnerabilidades e monitorar a segurança.



Manutenção

Monitorar, atualizar e corrigir falhas de segurança de forma contínua.

Implantação

Usar configurações seguras, escanear vulnerabilidades e monitorar a segurança em produção.



Manutenção

Monitorar, atualizar e corrigir falhas de segurança de forma contínua.

Os 5 Pilares da Segurança

ELICITAÇÃO DE REQUISITOS

A **elicitação eficaz de requisitos** garante que todos os aspectos de segurança sejam considerados desde o início do projeto.

DESIGN E ARQUITETURA SEGURA

Um design robusto e uma arquitetura segura são fundamentais para prevenir vulnerabilidades e garantir a **integridade do sistema**.

CODIFICAÇÃO SEGURA

A **codificação segura** implica seguir melhores práticas e diretrizes para evitar falhas comuns que podem ser exploradas por atacantes.

O Ciclo de Vida do Software Seguro

PLANEJAMENTO E CODIFICAÇÃO

O processo de desenvolvimento seguro começa com a definição de requisitos de segurança, seguidos pela codificação que evita falhas comuns.

TESTES E EVOLUÇÃO

Testes de penetração ajudam a identificar vulnerabilidades, enquanto a evolução contínua garante adaptações às novas ameaças e regulamentações emergentes.

Requisitos de Segurança e Compliance

IMPORTÂNCIA DOS REQUISITOS

A identificação das necessidades do usuário é crucial para garantir a **conformidade legal** com regulamentações como LGPD e GDPR.

COMPLIANCE LEGAL

Além disso, é essencial entender outras regulamentações globais para assegurar que os projetos atendam a todas as exigências necessárias.

Propriedades Fundamentais da Segurança

CONFIDENCIALIDADE E INTEGRIDADE

A segurança de software é sustentada por cinco propriedades essenciais: **Confidencialidade** protege dados; **Integridade** garante que informações não sejam alteradas indevidamente; **Disponibilidade** assegura que os usuários tenham acesso; **Autenticidade** verifica identidades; e **Não Repúdio** garante rastreabilidade.



Elicitação de Requisitos e Ameaças

STAKEHOLDERS ENVOLVIDOS

É essencial identificar os **stakeholders** que incluem usuários, clientes e especialistas para garantir requisitos precisos e relevantes na segurança.

TÉCNICAS DE COLETA

Utilizar **técnicas** como questionários e workshops ajuda a coletar requisitos de forma eficaz, permitindo um entendimento mais claro das necessidades dos usuários.

FOCO EM AMEAÇAS

A abordagem deve considerar **ameaças específicas** do domínio, permitindo a mitigação precoce e a proteção efetiva contra possíveis vulnerabilidades.

Proteção de Dados e Privacidade

COMPARAÇÃO ENTRE LGPD E GDPR

A GDPR É A LEI EUROPEIA DE PROTEÇÃO DE DADOS QUE SERVIU DE BASE PARA A CRIAÇÃO DA LGPD NO BRASIL, AMBAS REGULANDO COMO EMPRESAS COLETAM, UTILIZAM E PROTEGEM DADOS PESSOAIS.

Especificação e Métricas de Segurança

DOCUMENTAÇÃO PRECISA

A **documentação clara** é essencial para garantir que os requisitos de segurança sejam compreendidos e implementados adequadamente em cada fase do desenvolvimento.

EXEMPLOS DE MÉTRICAS

Métricas como o bloqueio após **cinco tentativas** de login falhas são importantes para a segurança e ajudam a prevenir acessos não autorizados.

REFERÊNCIA AO OWASP

O OWASP Top 10 fornece **diretrizes essenciais** para identificar e mitigar as vulnerabilidades mais críticas que os desenvolvedores devem abordar.

Testes de Segurança no Desenvolvimento

PAPEL DOS TESTES

Testes automatizados ajudam a identificar vulnerabilidades rapidamente, enquanto testes manuais oferecem uma análise mais profunda de possíveis falhas de segurança.

SIMULAÇÃO DE ATAQUES

Pentests simulam ataques reais para descobrir vulnerabilidades antes que possam ser exploradas, garantindo uma abordagem proativa à segurança do software.

Evolução Contínua da Segurança

ATUALIZAÇÕES NECESSÁRIAS

A segurança é um processo dinâmico que exige **atualizações constantes** para enfrentar novas vulnerabilidades e ameaças emergentes no ambiente digital.

MONITORAMENTO ATIVO

O monitoramento contínuo e a resposta rápida a incidentes são cruciais para garantir a proteção dos sistemas e dados contra ataques.

Conclusões e Encaminhamentos Finais

SEGURANÇA DESDE O INÍCIO



Perguntas?

"OBRIGADO! PERGUNTAS?"

